

Attack Tree Risk Analysis: Executive Summary for Pampered Pets

Github Link: <https://github.com/pecheylauren02/ism-attack-tree-assignment-lp>

Student Name: Lauren Pechey

Student ID: 12696823

Course: Masters of Computer Science

Module: Information Security Management

Professor: Dr Sabeen Tahir

Word Count: 1251 (*excluding tables, diagrams & reference list*)

New Submission Date: 15 June 2026

1. Introduction

This executive summary presents the findings of a Python-based attack tree risk analysis tool developed to quantify and visualise cybersecurity threats facing Pampered Pets. The application was built in response to the limitations of qualitative risk assessment methods, which, while appropriate for initial threat identification, do not provide business stakeholders with a concrete financial picture of risk exposure (Schneier, 1999; Hussain et al., 2024). By modelling threats as an attack tree and assigning monetary values to each node, the tool produces an expected monetary value (EMV) for each attack scenario, enabling direct comparison of risk before and after digitalisation controls are applied (Nadifi et al., 2025). The threats and mitigations modelled in this application are drawn directly from the baseline risk assessment submitted in Unit 3, ensuring continuity between the qualitative risk register and this quantitative threat analysis.

Attack trees model security threats hierarchically, with the attacker's objective at the root and the possible methods to achieve it branching downward as child nodes (Mauw and Oostdijk, 2005). Their hierarchical visual structure has been shown to be more intuitive for communicating security threats than alternative representations such as attack graphs, particularly for stakeholders without a deeply technical background (Lallie, Debattista and Bal, 2020). This makes attack trees well-suited to serving as an executive-level summary of risk for an SME such as Pampered Pets.

2. Application Overview

The tool was developed in Python and accepts attack tree specifications in JSON format, an industry-standard, human-readable data format natively supported by Python (Python Software Foundation, 2024). The application allows the user to enter probability and monetary impact values interactively at runtime for each leaf node. These values are then aggregated recursively up the tree to produce an overall risk score in pounds sterling (£).

The aggregation logic follows established attack tree semantics (Mauw and Oostdijk, 2005):

- **LEAF nodes** use Expected Monetary Value: $\text{risk} = \text{probability} \times \text{impact}$
- **OR nodes** return the maximum child risk, representing the worst-case attack path

- **AND nodes** return the sum of child risks, representing scenarios where all steps must succeed

The application was developed using NetworkX (v3.6.1) for graph construction and Matplotlib (v3.11.0) for visualisation, and produces a hierarchical tree diagram alongside a bar chart comparing pre- and post-digitalisation risk scores.

```
(venv) laurhen@Laurens-MacBook-Pro ism-attack-tree-assignment-lp % python3 main.py

=== ATTACK TREE RISK ANALYSIS TOOL ===

=====
PRE-DIGITALISATION
=====

Enter values for each leaf node:

Node: Wireless
Eavesdropping
  Probability (0.0-1.0): 0.7
  Impact (£): 60000

Node: Malware Injection
via Wi-Fi
  Probability (0.0-1.0): 0.6
  Impact (£): 80000

Node: Phishing /
Credential Compromise
  Probability (0.0-1.0): 0.7
  Impact (£): 45000

Node: Data Loss via
Legacy Warehouse System
  Probability (0.0-1.0): 0.65
  Impact (£): 70000

Node: POS System
Failure
  Probability (0.0-1.0): 0.5
  Impact (£): 35000
/Users/laurhen/Desktop/ism-attack-tree-assignment-lp/visualiser.py:52: UserWarning: This figure includes Axes that are not compatible with tight_layout, so results might be incorrect.
plt.tight_layout()

PRE-DIGITALISATION Risk: £48,000.00
```

Figure 1: Attack Tree Risk Analysis Tool - Terminal Output (Pre-Digitalisation)

```

=====
POST-DIGITALISATION
=====

Enter values for each leaf node:

Node: Wireless
Eavesdropping
    Probability (0.0-1.0): 0.2
    Impact (£): 60000

Node: Malware Injection
via Wi-Fi
    Probability (0.0-1.0): 0.15
    Impact (£): 80000

Node: Phishing /
Credential Compromise
    Probability (0.0-1.0): 0.25
    Impact (£): 45000

Node: Data Loss via
Legacy Warehouse System
    Probability (0.0-1.0): 0.1
    Impact (£): 70000

Node: POS System
Failure
    Probability (0.0-1.0): 0.2
    Impact (£): 35000

POST-DIGITALISATION Risk: £12,000.00

=== SUMMARY ===
Pre-Digitalisation Risk: £48,000.00
Post-Digitalisation Risk: £12,000.00
Risk Reduction: 75.00%

```

Figure 2: Attack Tree Risk Analysis Tool - Terminal Output (Post-Digitalisation)

To verify the correctness of the aggregation logic, unit tests were written and executed using pytest, with all six tests passing successfully (Figure 3). The codebase was also evaluated using the flake8 linter, producing a clean report with no errors or style violations (Figure 4).

```
● (venv) laurhen@Laurens-MacBook-Pro ism-attack-tree-assignment-lp % pytest
test_aggregator.py -v
===== test session starts =====
platform darwin -- Python 3.12.6, pytest-9.0.2, pluggy-1.6.0 -- /Library/Frameworks/Python.framework/Versions/3.12/bin/python3.12
cachedir: .pytest_cache
rootdir: /Users/laurhen/Desktop/ism-attack-tree-assignment-lp
plugins: anyio-4.12.1
collected 6 items

test_aggregator.py::test_leaf_basic PASSED [ 16%]
test_aggregator.py::test_leaf_zero_prob PASSED [ 33%]
test_aggregator.py::test_leaf_zero_impact PASSED [ 50%]
test_aggregator.py::test_or_takes_max PASSED [ 66%]
test_aggregator.py::test_and_sums_children PASSED [ 83%]
test_aggregator.py::test_unknown_type PASSED [100%]

===== 6 passed in 0.04s =====
```

Figure 3: pytest Unit Test results

```
● (venv) laurhen@Laurens-MacBook-Pro ism-attack-tree-assignment-lp % flake8
main.py attack_tree.py aggregator.py visualiser.py
○ (venv) laurhen@Laurens-MacBook-Pro ism-attack-tree-assignment-lp %
```

Figure 4: flake8 Results: all clear

3. Pre-Digitalisation Threat Model

The pre-digitalisation attack tree models the current as-is environment at Pampered Pets, which operates with shared wireless connectivity, a legacy spreadsheet-based warehouse system, unmanaged staff endpoints, and a single point-of-failure POS system. These vulnerabilities were identified in the Unit 3 baseline risk report. SMEs operating in this manner are particularly exposed, as they typically lack the formal security governance and dedicated resources needed to manage threats effectively (Aoudi and Al-Aqrabi, 2026). The specific threats modelled here (wireless interception, malware injection, phishing, data loss, and system failure) reflect the most

prevalent attack vectors reported against organisations with low cybersecurity maturity (Humayun et al., 2020; NIST, 2023).

The tree is structured as follows: the root node, "Pampered Pets System Compromise", is an OR node with three child branches — Network Threats, Internal Threats, and POS System Failure. This reflects the reality that any one of these attack paths, if successful, could result in significant business impact (OWASP, 2024).

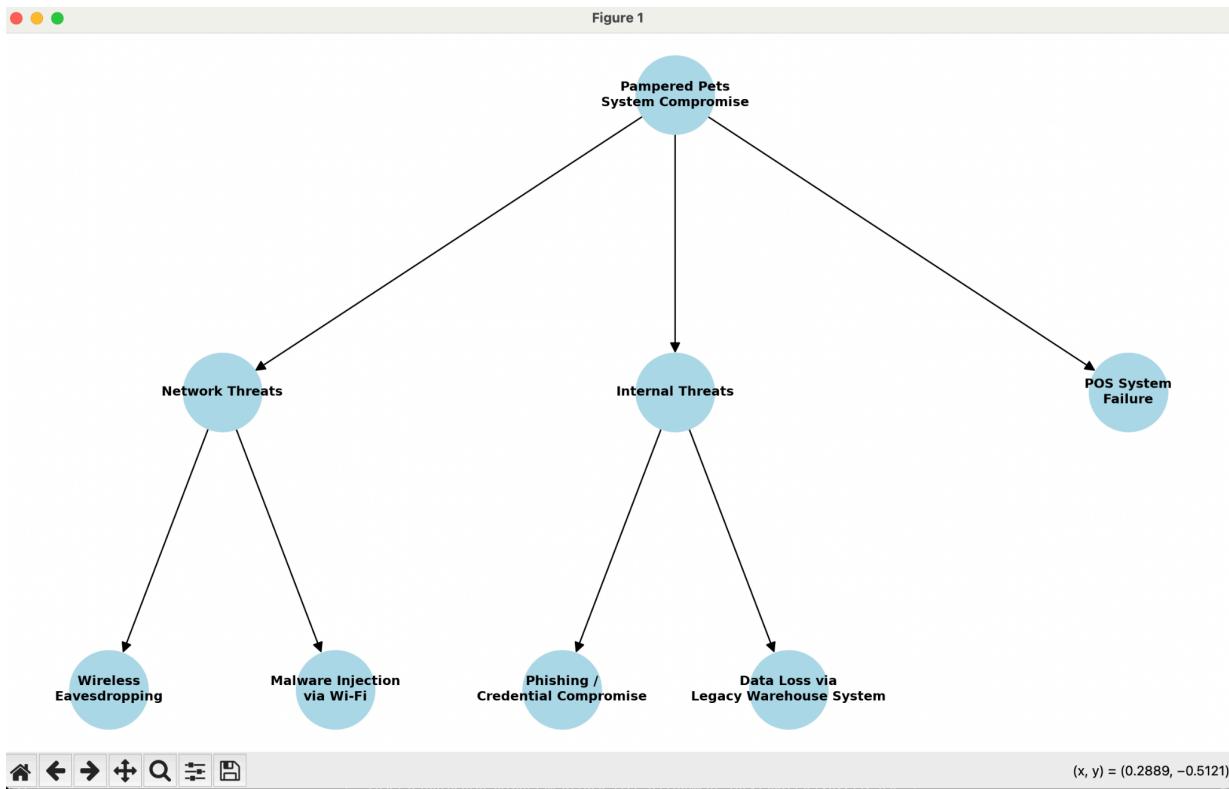


Figure 5: Attack Tree Visualisation — Pre-Digitalisation Threat Model (Pampered Pets)

Table 1 below summarises the probability and impact values assigned to each leaf node and the resulting EMV:

Threat	Probability	Impact (£)	EMV (£)
Wireless Eavesdropping	0.70	£ 60,000	£ 42,000
Malware Injection via Wi-Fi	0.60	£ 80,000	£ 48,000

Phishing / Credential Compromise	0.70	£ 45,000	£ 31,500
Data Loss via Legacy Warehouse System	0.65	£ 70,000	£ 45,500
POS System Failure	0.50	£ 35,000	£ 17,500

Table 1: Pre-Digitalisation Leaf Node Risk Values

The OR aggregation logic selects the highest-risk path at each branch. Network Threats resolve to £48,000 (malware injection), Internal Threats resolve to £45,500 (data loss), and the root OR node resolves to the overall worst-case score of £48,000. This represents the maximum expected monetary loss to Pampered Pets under current conditions.

4. Post-Digitalisation Threat Model

The post-digitalisation tree retains the same structure but reflects the reduced threat probabilities achieved through the security controls recommended in the Unit 3 baseline report: network segmentation, multi-factor authentication (MFA), endpoint protection software, automated backups, patch management, and cybersecurity awareness training, all aligned with ISO/IEC 27001 controls and the NIST Risk Management Framework (ISO, 2022; NIST, 2023).

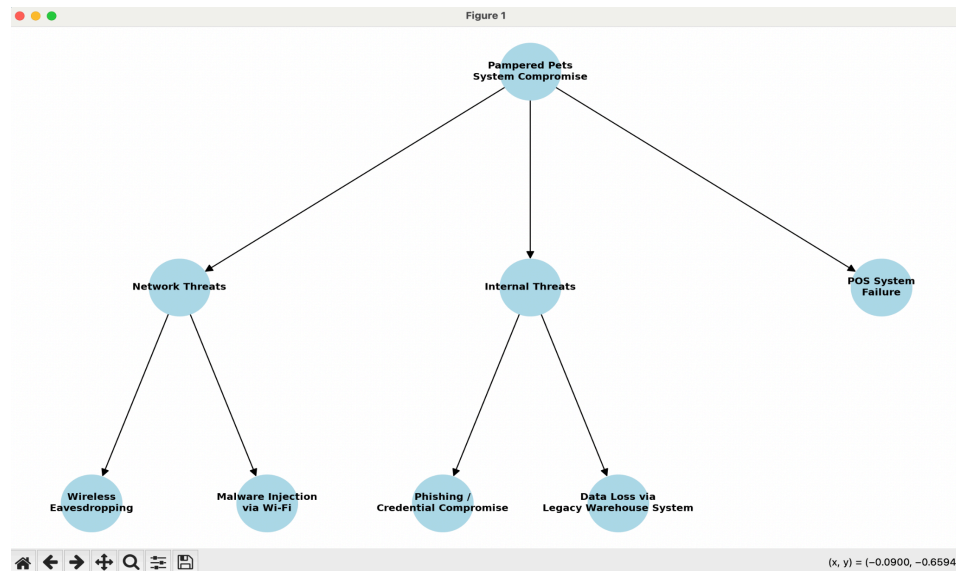


Figure 6: Attack Tree Visualisation — Post-Digitalisation Threat Model (Pampered Pets)

Please note: Both trees share the same structure as the threats remain unchanged. The difference lies in the reduced leaf node probabilities post-digitalisation, as shown in Tables 1 and 2.

Table 2 presents the updated values following control implementation:

Threat	Probability	Impact (£)	EMV (£)
Wireless Eavesdropping	0.20	£ 60,000	£ 12,000
Malware Injection via Wi-Fi	0.15	£ 80,000	£ 12,000
Phishing / Credential Compromise	0.25	£ 45,000	£ 11,250
Data Loss via Legacy Warehouse System	0.10	£ 70,000	£ 7,000
POS System Failure	0.20	£ 35,000	£ 7,000

Table 2: Post-Digitalisation Leaf Node Risk Values

Network Threats resolve to £12,000, Internal Threats to £11,250, and the root OR node resolves to an overall risk score of £12,000. The financial impact of each threat remains unchanged, as monetary damages are determined by the nature of the threat rather than the controls in place. It is the probability of exploitation that decreases as controls mature (Lincke, 2024).

5. Risk Comparison and Findings

The application produces a comparative bar chart visualising the reduction in expected monetary risk between the two scenarios.

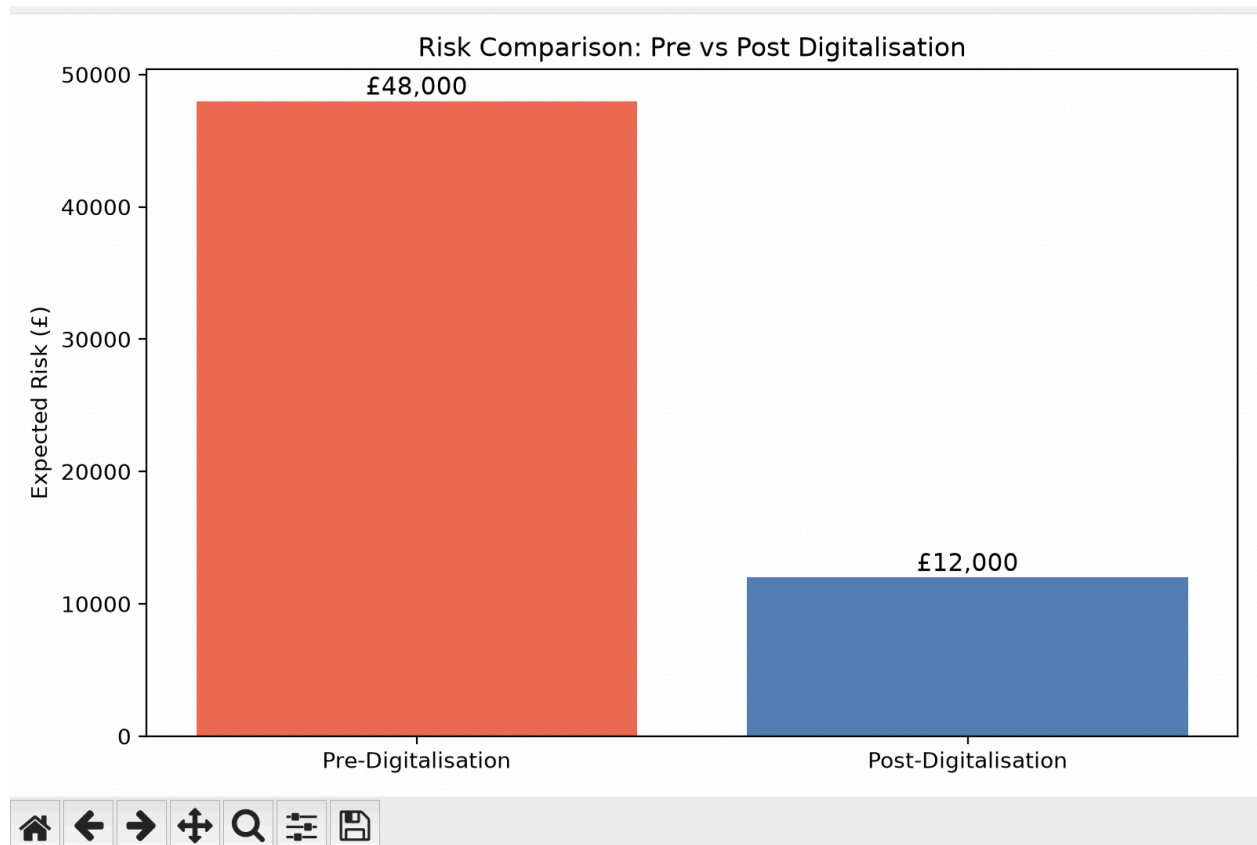


Figure 4: Risk Comparison Bar Chart — Pre vs Post Digitalisation Expected Monetary Risk (£)

Table 3 shows the risk reduction summary between pre and post-digitalisation:

Scenario	Overall Risk Score
Pre-Digitalisation	£ 48,000
Post-Digitalisation	£ 12,000
Risk Reduction	75.00%

Table 3: Risk Reduction Summary

The 75% reduction in expected monetary risk demonstrates the tangible financial benefit of the recommended security controls. This aligns with the broader argument made in the Unit 3 baseline report that digital transformation, when accompanied by structured security governance, results in manageable and significantly reduced cyber risk compared to the status quo

(Egho-Promise et al., 2024). It is worth noting that while the e-commerce platform and cloud infrastructure introduced through digitalisation create new attack surfaces, these are offset by the significant reductions in probability across all pre-existing threats, resulting in a net improvement in the overall risk position (Kokrobo et al., 2025).

It is important to acknowledge a limitation of this model: the OR aggregation logic selects only the maximum-risk path at each branch, meaning it does not account for the cumulative probability of multiple simultaneous attacks (Benjamin et al., 2024). In practice, Pampered Pets could face concurrent threats, which would increase total exposure beyond the figure shown here (Mauw and Oostdijk, 2005). This model therefore represents a conservative, worst-case single-path estimate rather than a full probabilistic simulation.

6. Conclusion

This attack tree analysis provides Pampered Pets with a quantified, financially grounded view of its cybersecurity risk exposure. The pre-digitalisation environment carries an expected monetary risk of £48,000 under the most likely attack scenario. With the recommended controls in place, this figure falls to £12,000, representing a 75% risk reduction. These findings reinforce the recommendation made in the Unit 3 report that Pampered Pets proceed with digital transformation under a phased, security-governed implementation plan aligned with ISO/IEC 27001 and the NIST RMF (ISO, 2022; Marsland, 2024). The Python application developed for this analysis serves as a reusable tool that can be updated as the threat landscape evolves, supporting ongoing risk governance for the business.

References:

- Aoudi, S. and Al-Aqrabi, H. (2026) 'Integrating IoT security practices into a risk-based framework for small and medium enterprises (SMEs)', *Computer Standards & Interfaces*, 97, p. 104099.
- Benjamin, L.B., Adegbola, A.E., Amajuoyi, P., Adegbola, M.D. and Adeusi, K.B. (2024) 'Digital transformation in SMEs: Identifying cybersecurity risks and developing effective mitigation strategies', *Global Journal of Engineering and Technology Advances*, 19(2), pp. 134–153. DOI: <https://doi.org/10.30574/gjeta.2024.19.2.0084>
- Egho-Promise, E., Lyada, E., Asante, G. and Anna, F. (2024) 'Towards improved vulnerability management in digital environments', *International Research Journal of Computer Science*, 11(5), pp. 441–449.
- Humayun, M., Niazi, M., Jhanjhi, N., Alshayeb, M. and Mahmood, S. (2020) 'Cyber security threats and vulnerabilities: A systematic mapping study', *Arabian Journal for Science and Engineering*, 45(4), pp. 3171–3189.
- Hussain, A.H., Islam, M.M., Hassan, M.M., Hasan, M.N. and Islam, S. (2024) 'Operationalizing the NIST AI RMF for SMEs', *Journal of International Crisis and Risk Communication Research*, 7(S6), p. 2555.
- ISO. (2022) *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection*. Available at: <https://www.iso.org/standard/27001>
- Kokroko, B.Y., Kobi, J. and Yeboah, E.K. (2025) 'Risk assessment models identify potential supply chain disruptions through scenario analysis Monte Carlo simulation predictive analytics', *International Journal of Innovative Science and Research Technology*, 10(10), p. 2765. DOI: <https://doi.org/10.38124/ijisrt/25oct1432>
- Lallie, H.S., Debattista, K. and Bal, J. (2020) 'A review of attack graph and attack tree visual syntax in cyber security', *Computer Science Review*, 35, p. 100219.

- Lincke, S. (2024) *Information security planning: A practical approach*. Cham: Springer International Publishing.
- Marsland, T. (2024) *Unveiling the NIST Risk Management Framework (RMF)*. Birmingham: Packt Publishing Ltd.
- Mauw, S. and Oostdijk, M. (2005) 'Foundations of Attack Trees', *Information Security and Cryptology*, LNCS 3935, pp. 186–198.
- Nadifi, Z., Ouaisa, M., Ouaisa, M., Alhyan, M. and Kartit, A. (2025) 'STRIDE-based threat modeling and risk assessment framework for IoT-enabled smart healthcare systems', *International Journal of Online and Biomedical Engineering*, 21(9), p. 63. DOI: <https://doi.org/10.3991/ijoe.v21i09.55517>
- NIST. (2023) *National Vulnerability Database*. Available at: <https://nvd.nist.gov/>
- OWASP. (2024) *OWASP Web Security Testing Guide (WSTG)*. Available at: <https://owasp.org/www-project-web-security-testing-guide/> [Accessed 28 June 2025].
- Python Software Foundation. (2024) *json — JSON encoder and decoder*. Available at: <https://docs.python.org/3/library/json.html>
- Schneier, B. (1999) 'Attack Trees', *Dr Dobbs's Journal*, 24(12), pp. 21–29.